UNIVERSIDAD VERACRUZANA

Protección de Servicios

EXAMEN PARCIAL 1 - PARTE PRÁCTICA

Nombre del estudiante: _____

Fecha: _____

Máquina servidor: examen-servicios

Máquina cliente: cliente-examen

Caso: MercadoNova

MercadoNova es una empresa dedicada al comercio electrónico. A través de su plataforma, los clientes pueden consultar productos, realizar solicitudes de compra y proporcionar información necesaria para el procesamiento y entrega de sus pedidos.

Parte de su infraestructura funciona sobre un servidor Linux en el que se encuentran servicios web, archivos de configuración, cuentas utilizadas por personal técnico e información relacionada con clientes y respaldos. Durante los últimos meses, el servidor ha sido administrado por diferentes integrantes del área de tecnología. También se han creado cuentas para personal de soporte y proveedores externos que participaron temporalmente en actividades de mantenimiento.

Aunque actualmente el servicio se encuentra funcionando, la empresa no cuenta con evidencia suficiente para demostrar que las configuraciones de seguridad existentes continúan siendo adecuadas. Tampoco se ha realizado recientemente una revisión integral de privilegios, accesos remotos, servicios expuestos, protección de archivos, firewall o almacenamiento.

La dirección de MercadoNova solicita realizar un diagnóstico técnico de seguridad antes de continuar utilizando el servidor, con el objetivo de identificar configuraciones que puedan representar un riesgo y aplicar los controles necesarios sin afectar el funcionamiento legítimo del servicio.

La revisión deberá considerar que un servidor no puede considerarse protegido únicamente porque se encuentre dentro de una red interna. Un usuario con privilegios excesivos, una cuenta que permanezca activa más tiempo del necesario, un servicio expuesto incorrectamente o información sensible sin protección pueden facilitar un incidente.

Entorno proporcionado

Máquina	Función	Dirección IP
examen-servicios	Servidor de MercadoNova que deberá analizarse y protegerse	192.168.50.10
cliente-examen	Equipo para realizar pruebas de acceso y conectividad	192.168.50.20

Ambas máquinas se encuentran conectadas mediante la red interna red-examen. La máquina cliente-examen se proporciona como herramienta de comprobación. El estudiante deberá decidir qué pruebas necesita realizar para demostrar que las configuraciones aplicadas funcionan correctamente.

Condiciones de seguridad de MercadoNova

Usuarios y privilegios

Los usuarios deberán poseer únicamente los privilegios necesarios para desempeñar su función. Las cuentas utilizadas temporalmente deberán tener una vigencia definida y no permanecer activas indefinidamente.

Acceso administrativo mediante SSH

El acceso remoto se realiza mediante SSH (Secure Shell), protocolo utilizado para administrar sistemas de manera remota. La configuración deberá cumplir con los siguientes criterios:

- impedir el acceso remoto directo como root;
- limitar los intentos de autenticación;
- utilizar cuentas individuales;
- mostrar un banner o aviso de uso restringido antes del inicio de sesión;
- proteger adecuadamente las llaves criptográficas utilizadas para autenticación.

La llave privada deberá permanecer bajo control de su propietario y no almacenarse en el servidor al que permite acceder. Cambiar únicamente el puerto utilizado por SSH no será considerado un control de seguridad suficiente.

Firewall de host

El servidor deberá contar con un firewall de host activo. La política será denegar por defecto las conexiones entrantes y permitir únicamente aquellas necesarias para el funcionamiento y administración del servicio. Los servicios legítimos deberán continuar funcionando después de aplicar el control.

Protección de archivos

Los archivos que contengan configuraciones o información sensible deberán disponer de permisos acordes con las funciones de los usuarios y servicios que realmente necesiten utilizarlos.

Protección del almacenamiento

Los volúmenes utilizados para almacenar información sensible deberán analizarse para determinar si cuentan con protección criptográfica. Cuando sea necesario, deberá proponerse una tecnología adecuada, como LUKS (Linux Unified Key Setup), utilizada para cifrar dispositivos o volúmenes de almacenamiento en Linux. No deberá eliminarse ni dañarse el archivo clientes.txt.

Actividades a realizar

1. Diagnóstico inicial

Antes de modificar el servidor, realiza una revisión general que permita conocer su estado actual. Deberás revisar usuarios y privilegios, cuentas temporales, servicios y puertos, configuración SSH y banner, firewall, permisos de archivos sensibles, almacenamiento y estado del cifrado. Conserva evidencia del estado encontrado.

2. Identificación y análisis de riesgos

A partir del diagnóstico, identifica las configuraciones que consideres inseguras o inadecuadas. Por cada hallazgo describe la situación encontrada, el riesgo, el impacto y el control necesario. Indica también si puede afectar principalmente a la confidencialidad, integridad o disponibilidad de la información o del servicio.

3. Aplicación de controles

Corrige las configuraciones que puedan modificarse de manera segura durante el examen. Las correcciones deberán considerar lo trabajado durante el curso sobre mínimo privilegio, cuentas temporales, SSH, banner, firewall de host, permisos, llaves criptográficas y protección de información. En el caso del almacenamiento cifrado, no será necesario convertir el volumen a LUKS durante el examen; deberás realizar el diagnóstico y explicar la solución que aplicarías.

4. Verificación

Después de realizar las correcciones, demuestra que los controles funcionan. Cuando corresponda, realiza una prueba positiva para demostrar que una actividad autorizada continúa funcionando y una prueba negativa para demostrar que una actividad que no debería permitirse es rechazada. Podrás utilizar cliente-examen para realizar estas comprobaciones.

5. Análisis del almacenamiento

Determina si el volumen destinado a información de clientes se encuentra protegido mediante cifrado. Explica brevemente la situación encontrada, el riesgo, la tecnología que utilizarías, cómo comprobarías que el volumen quedó protegido y qué riesgo permanecería cuando el volumen estuviera desbloqueado.

Producto a entregar

El estudiante entregará un reporte técnico en formato PDF. La parte principal del reporte deberá presentar los hallazgos y evidencias de manera clara y ordenada, utilizando la siguiente estructura:

Hallazgo	Evidencia inicial	Riesgo e impacto	Control o corrección	Evidencia final

Las evidencias deberán mostrar claramente el estado antes y después cuando se haya realizado una modificación. Cuando corresponda, deberá incluirse evidencia de una prueba positiva y una prueba negativa.

Protección del almacenamiento

Incluye un apartado breve con el diagnóstico del volumen, el riesgo identificado y la propuesta de protección mediante cifrado.

Conclusión

Responde brevemente: ¿Cuál de los riesgos encontrados consideras que representaba el mayor peligro para MercadoNova y por qué? ¿Qué riesgo relevante continúa existiendo aun después de aplicar los controles?

IMPORTANTE: Una captura de pantalla por sí sola no constituye una explicación técnica. Cada evidencia deberá incluir una breve interpretación que indique qué se comprobó y por qué el resultado es relevante.